

README – Kit de Encuesta GQM + PRAGMATIC para indicadores CVSS v4.0

1. ¿Qué es este kit?

Este kit reúne los elementos necesarios para diseñar, evaluar y explotar un sistema de indicadores de vulnerabilidades basado en CVSS v4.0 a nivel nacional, sectorial y territorial, siguiendo la metodología GQM y los criterios PRAGMATIC. [web:1][web:16][web:22][web:21][web:24]

Incluye:

- Marco conceptual GQM + PRAGMATIC.
- Matriz de evaluación PRAGMATIC.
- Narrativa explicativa para contextualizar el uso del modelo.
- Mapeo de preguntas a requisitos normativos.
- Plantilla de Excel para IGM y ROI.
- Plantilla de reporte ejecutivo en formato PowerPoint.

2. Público objetivo

- Responsables de ciberseguridad en ministerios, CCAA y organismos reguladores.
- CSIRTs nacionales y sectoriales.
- Operadores de servicios esenciales y entidades NIS2. [web:7][web:13][web:12]
- Equipos de análisis de riesgo y continuidad de negocio que necesiten traducir CVSS al lenguaje del regulador y del consejo de administración.

3. Cómo usar el kit (orden recomendado)

1. Leer el “Marco integrativo GQM + PRAGMATIC”
Para entender el enfoque y alinear objetivos, preguntas y métricas. [web:26][web:27]
2. Revisar la “Narrativa explicativa”
Para disponer de argumentos y lenguaje que facilite la comunicación interna y política.
3. Seleccionar métricas candidatas y evaluarlas con la “Matriz de Evaluación PRAGMATIC”
Para filtrar métricas inútiles y priorizar las que aportan mayor valor. [web:21][web:24][web:27]
4. Usar el “Mapeo detallado de preguntas a requisitos normativos”
Para asegurar que los indicadores escogidos dan soporte a obligaciones de NIS2 y otras normativas.
[web:7][web:13][web:12]
5. Implementar la plantilla de Excel
6. Rellenar las puntuaciones PRAGMATIC para cada métrica adoptada.
7. Calcular el IGM por unidad.
8. Estimar el ROI de iniciativas de mejora.
9. Preparar el reporte ejecutivo con la plantilla de PowerPoint
Para presentar resultados y decisiones requeridas a órganos de gobierno y alta dirección.

Leer el “Marco integrativo GQM + PRAGMATIC”

Para entender el enfoque y alinear objetivos, preguntas y métricas. [web:26][web:27]

Revisar la “Narrativa explicativa”

Para disponer de argumentos y lenguaje que facilite la comunicación interna y política.

Seleccionar métricas candidatas y evaluarlas con la “Matriz de Evaluación PRAGMATIC”

Para filtrar métricas inútiles y priorizar las que aportan mayor valor. [web:21][web:24][web:27]

Usar el “Mapeo detallado de preguntas a requisitos normativos”

Para asegurar que los indicadores escogidos dan soporte a obligaciones de NIS2 y otras normativas.
[web:7][web:13][web:12]

Implementar la plantilla de Excel

Estimar el ROI de iniciativas de mejora.

Preparar el reporte ejecutivo con la plantilla de PowerPoint

Para presentar resultados y decisiones requeridas a órganos de gobierno y alta dirección.

4. Principios de diseño del kit

- Trazabilidad: cada número debe poder explicarse por una pregunta y un objetivo. [web:26][web:29]
- Parquedad cruel: mejor pocas métricas muy buenas que muchas mediocres; PRAGMATIC se usa para decir “no”. [web:21][web:24][web:27]
- Compatibilidad europea: el uso de CVSS v4.0, Threat, Environmental y Supplemental y la referencia a EUVD y NIS2 garantizan alineamiento con el marco europeo. [web:1][web:7][web:13][web:22]
- Escalabilidad territorial: las métricas están pensadas para agregarse y desagregarse por CCAA, sector y tipo de entidad.

5. Requisitos previos

Para aprovechar el kit, es recomendable disponer de:

- Catálogo de activos y servicios, con identificación de servicios expuestos y servicios esenciales. [web:22]
- Proceso de gestión de vulnerabilidades con scoring CVSS v4.0 (al menos Base; idealmente Threat y Environmental). [web:1][web:16][web:22]
- Mecanismos de reporting de incidentes alineados con NIS2. [web:7][web:13]
- Capacidad básica de explotación de datos (Excel/BI).

6. Adaptación y extensiones

El kit está pensado como base común. Se anima a:

- Ajustar objetivos GQM a contextos sectoriales específicos (sanidad, energía, transporte). [web:10][web:12]
- Refinar la matriz PRAGMATIC con pesos ajustados a prioridades nacionales. [web:21][web:24]
- Incorporar métricas adicionales derivadas de CVSS Supplemental específicas para entornos OT e industriales. [web:1][web:10][web:18]

7. Contacto y gobernanza

Se recomienda que una entidad nacional (por ejemplo, INCIBE / NCC-ES, en coordinación con ministerios competentes) mantenga este kit, publique versiones actualizadas y coordine su adaptación a nuevas versiones de CVSS o cambios normativos europeos. [web:7][web:12][web:22]

Mientras tanto, si has llegado hasta aquí y sigues sin odiar las métricas, probablemente eres parte del problema, pero también de la solución.